

NETWORK WALKS

PENETRATION TESTING REPORT

MEDIROZA GENERAL HOSPITAL

Pentester Name	Yuvraj Atul Kale
Batch	B082
Date	6 September 2026
Milestones Completed	M1 - Initial Access M2 - Data Extraction M3 - Critical Data Exposure M4 - Documentation
Client name	<u>Mediroza General Hospital</u>
Target	https://medirozahospital.com
Permission secured from client?	Yes

1.DISCLAIMER

This report has been prepared for the authorized penetration-testing assessment of Mediroza General Hospital. All testing was conducted within the approved scope and according to the defined rules of engagement. The findings and evidence documented in this report represent the results of the activities performed during the assessment and do not guarantee that every possible vulnerability has been identified.

2.EXECUTIVE SUMMARY

A full black-box penetration test was conducted against the Mediroza General Hospital web application within the authorized assessment scope.

The assessment identified weaknesses in authentication, document protection, database security, and access controls. These weaknesses allowed the tester to obtain unauthorized access, retrieve protected patient reports, recover document passwords, and access sensitive database information.

The most significant finding was the exposure of sensitive employee salary and shareholder ownership information through an exposed database backup and SQL-based data access.

The combined findings represent a significant security risk, particularly due to the exposure of sensitive personal and organizational information.

The following sections document the confirmed findings, supporting evidence, risk, and recommended remediation.

2.1 Assessment Objectives

- Identify vulnerabilities within the Mediroza General Hospital web application.
- Validate whether identified weaknesses could be practically exploited.
- Determine the extent of unauthorized access achievable through the identified vulnerabilities.
- Assess whether sensitive patients, employees, shareholders, or organizational information can be accessed.
- Collect sufficient evidence to support each confirmed finding.
- Provide practical remediation recommendations to reduce the identified security risks.

2.2 Key Findings

- Authentication bypass leading to unauthorized application access.
- Retrieval of three patient reports.
- Recovery of passwords protecting the retrieved PDF documents.
- Exposure of an old database backup.
- SQL Injection allowing access to database information.
- Exposure of employee salary information.
- Exposure of shareholder ownership information.

3.SCOPE & METHODOLOGY

3.1 Scope

The assessment targeted the authorized Mediroza General Hospital web application and focused on identifying vulnerabilities that could lead to unauthorized access, data extraction, or sensitive information exposure.

3.2 Methodology

The assessment followed the following process:

1. Reconnaissance – Identify the target attack surface and accessible resources.
2. Enumeration – Identify application functionality, endpoints, and exposed resources.
3. Vulnerability Identification – Analyze the application for exploitable security weaknesses.
4. Exploitation – Safely validate identified vulnerabilities within the authorized environment.
5. Data Validation – Determine the sensitivity and impact of information accessible through successful exploitation.
6. Evidence Collection – Capture screenshots and supporting evidence for confirmed findings.
7. Reporting – Document findings, risk, evidence, and remediation recommendations.

3.3 Limitations

- Testing was restricted to the authorized Mediroza General Hospital web application and defined assessment scope.
- The assessment was performed as a black-box test, with limited prior knowledge of the internal application architecture.
- Testing was conducted within the available assessment period and therefore does not guarantee identification of every possible vulnerability.
- Exploitation was limited to controlled validation required to demonstrate the impact of identified vulnerabilities; destructive actions were avoided.
- Findings and conclusions represent the security posture observed during the assessment period and may change following application updates or remediation.

4.TOOLS USED

The following tools were used during the assessment for reconnaissance, web application testing, vulnerability validation, and evidence collection.

Tools	Purpose
Kali Linux	Primary penetration testing environment
Curl	HTTP requests, header & endpoint analysis
Burp Suite	Web application traffic interception, request analysis, and security testing
Firefox/Brave Browser	Manual application interaction, authentication testing, and resource access validation
SQL / Command-Line Utilities	Database interaction, SQL Injection validation, data extraction, and supporting analysis

4.1 Testing Approach

Tools were selected according to the requirements of each assessment phase. Testing combined automated enumeration with manual validation to confirm the practical impact of identified vulnerabilities.

4.2 Testing Techniques

The assessment combined manual and tool-assisted testing techniques, including:

- Network and service enumeration to identify accessible services and potential attack surfaces.
- Web application testing to evaluate authentication, authorization, and accessible application functionality.
- Request and response analysis to identify weaknesses in application behavior and security controls.
- SQL Injection testing to validate database-level security and determine whether unauthorized data could be retrieved.
- Password recovery testing against the protected PDF documents to assess the effectiveness of their password protection.
- Manual validation of discovered vulnerabilities to confirm their practical impact before documenting them as findings.

5.Milestone-1: INITIAL ACCESS

5.1 Authentication Bypass

The authentication mechanism was tested for weaknesses that could allow access without valid authorization. The identified weakness was successfully validated, resulting in unauthorized application access.

Evidence

Figure 5.1 – Authentication bypass demonstrating unauthorized access.

The screenshot shows a web browser window with the URL `medirozahospital.com/patient/login.php`. The page features a dark blue header with the Mediroza logo, navigation links (Home, About, Doctors, Contact, Patient Portal), and emergency contact information. The main content area is light blue and contains a white 'Patient Portal' login form. The form has fields for 'Username' (containing a redacted value) and 'Password' (containing 'anything029938373'). A 'Show password' checkbox is checked. A 'Sign in' button is at the bottom of the form. The footer of the page states: '© 2026 Mediroza General Hospital. All rights reserved. Powered by Mediroza CMS'.

Impact

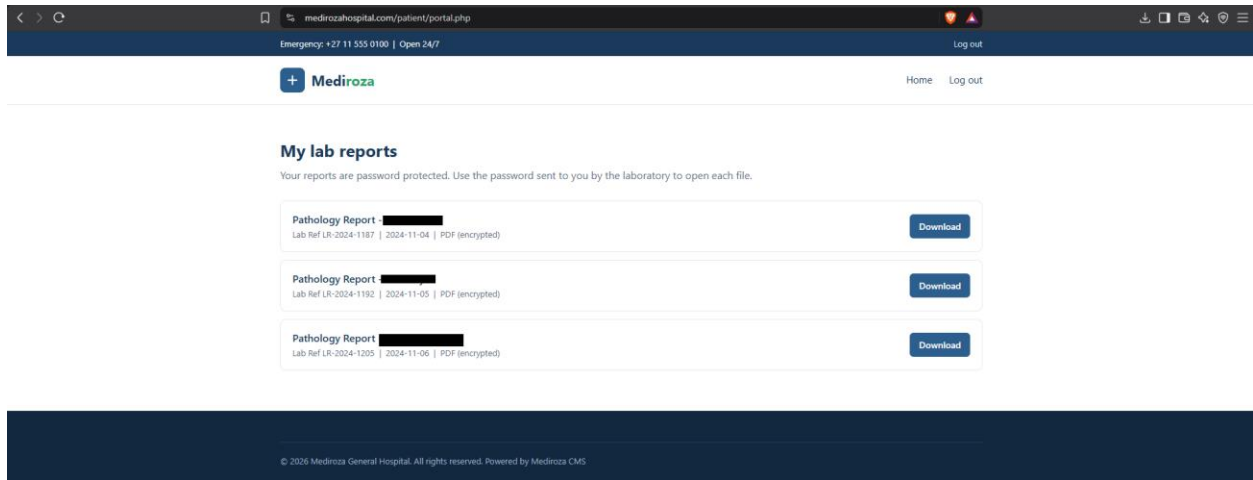
An attacker able to bypass the authentication mechanism could gain access to application functionality intended for authenticated users.

5.2 Patient Portal Access

Following successful authentication bypass, access to the patient portal was obtained.

Evidence

Figure 5.2 – Patient portal accessed following authentication bypass.



Impact

Unauthorized access to the patient portal could expose patient-related functionality and information to an attacker.

5.3 Patient Report Access

The assessment demonstrated access to three patient reports through the application.

Evidence

Figure 5.3 – Three patient reports accessible through the application.

Name	Date modified	Type	Size
 patient_report_1	05-09-2026 22:33	Brave HTML Docu...	4 KB
 patient_report_2	05-09-2026 22:33	Brave HTML Docu...	4 KB
 patient_report_3	05-09-2026 22:33	Brave HTML Docu...	4 KB

Impact

Unauthorized access to patient reports represents a confidentiality risk because information intended for authorized users may be accessible without appropriate authorization.

6.Milestone-2: DATA EXTRACTION

Following the initial access obtained during M1, further testing was performed to assess access to protected patient documents.

Three patient PDF reports were successfully retrieved. The security of the documents was then assessed by extracting their hashes and recovering the associated passwords, allowing the documents to be decrypted and verified.

6.1 PDF 1 – Access & Password Recovery

PDF 1 was successfully accessed during the assessment. The associated password protection was subsequently tested and the password was recovered.

Evidence

Figure 6.1 – Access to PDF 1.

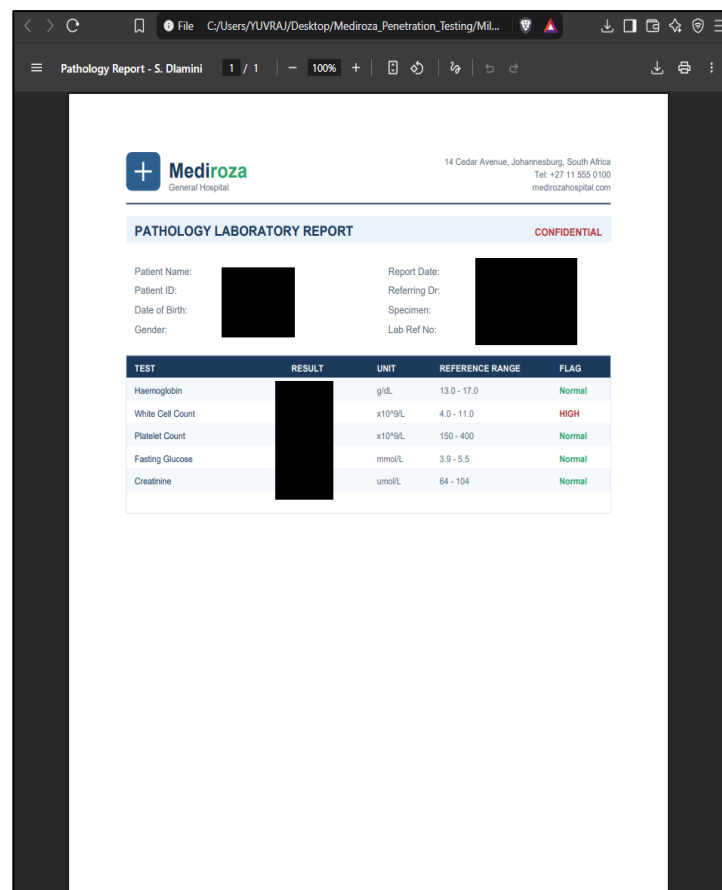


Figure 6.2 – Password recovery for PDF 1.

```
(kali㉿kali)-[~]
$ pdfcrack -f ~/Downloads/patient_report_1.pdf -w /usr/share/wordlists/rockyou.txt
PDF version 1.4
Security Handler: Standard
V: 2
R: 3
P: -4
Length: 128
Encrypted Metadata: True
FileID:
U: ef16
O: c431
found user-password: 
```

6.2 PDF 2 – Access & Password Recovery

PDF 2 was successfully accessed and its password protection was subsequently tested. The associated password was recovered during the assessment.

Evidence

Figure 6.3 – Access to PDF 2.

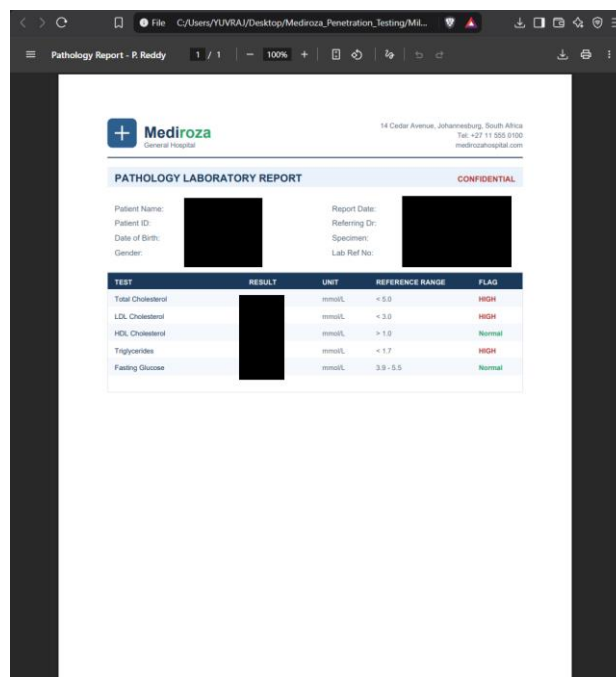


Figure 6.4 – Password recovery for PDF 2.

```
(kali@kali)-[~]
$ pdfcrack -f ~/Downloads/patient_report_2.pdf -w /usr/share/wordlists/rockyou.txt
PDF version 1.4
Security Handler: Standard
V: 2
R: 3
P: -4
Length: 128
Encrypted Metadata: True
FileID:
U: 39f4e
O: 408b1
found user-password:
```

6.3 PDF 3 – Access & Password Recovery

PDF 3 was successfully accessed during the assessment. Its password protection was subsequently tested and the associated password was recovered.

Evidence

Figure 6.5 – Access to PDF 3.

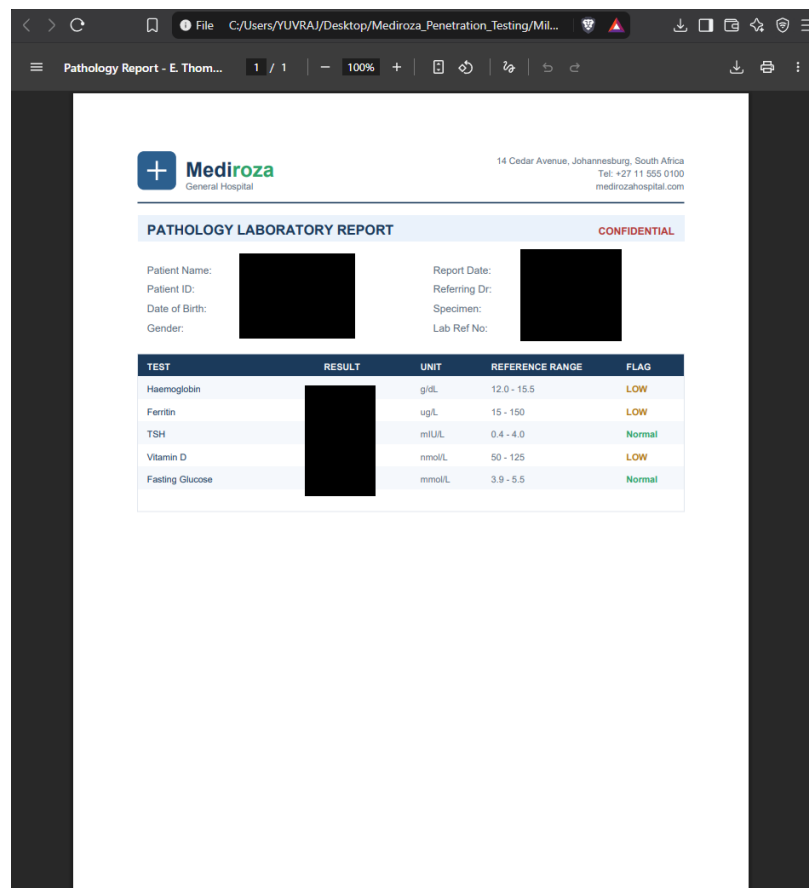


Figure 6.6 – Password recovery for PDF 3.

7.1 Exposed Database Backup

An old database backup was discovered within a publicly accessible location. The backup contained database information belonging to the Mediroza environment.

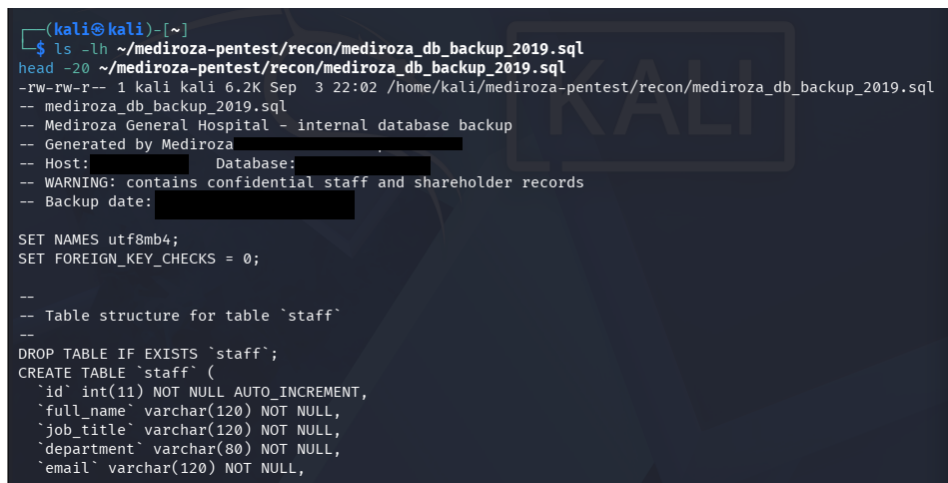
The availability of a database backup through the web-accessible environment significantly increases the potential attack surface because database dumps may contain sensitive applications and organizational information.

Impact

An attacker able to obtain the backup could analyze its contents offline and potentially retrieve sensitive information without interacting directly with the application's security controls.

Evidence

Figure 7.1 – Exposed database backup identified during the assessment.

A terminal window on a Kali Linux machine showing the discovery of a database backup file. The user runs 'ls -lh' in the directory ~/mediroza-pentest/recon, listing the file mediroza_db_backup_2019.sql. They then run 'head -20' to view the first 20 lines of the file. The output shows the file's permissions, size, and date, followed by a series of comments and SQL statements. The comments indicate it's an internal database backup for Mediroza General Hospital, generated by Mediroza, and contains confidential staff and shareholder records. The SQL statements include setting the character set to utf8mb4, disabling foreign key checks, and creating a table named 'staff' with columns for id, full_name, job_title, department, and email.

```
(kali@kali)-[~]
$ ls -lh ~/mediroza-pentest/recon/mediroza_db_backup_2019.sql
head -20 ~/mediroza-pentest/recon/mediroza_db_backup_2019.sql
-rw-rw-r-- 1 kali kali 6.2K Sep  3 22:02 /home/kali/mediroza-pentest/recon/mediroza_db_backup_2019.sql
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza
-- Host: Database:
-- WARNING: contains confidential staff and shareholder records
-- Backup date:

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table `staff`
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
```

7.2 Employee Salary Data Exposure

The exposed database contained an employee-related table containing sensitive employment and salary information.

The assessment identified records containing:

- Employee name
- Job role
- Department
- Monthly salary
- Joining date

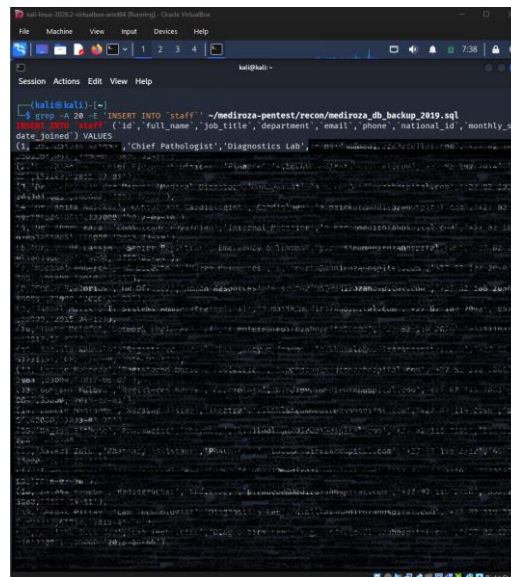
The exposed information represented salary records for 20 hospital employees.

Impact

Unauthorized access to employee salary and employment information represents significant confidentiality and privacy risk. Such information could be misused for targeted attacks, social engineering, or other malicious purposes.

Evidence

Figure 7.2 – SQL output demonstrating exposed employee salary information.



The screenshot shows a terminal window with a dark background. At the top, there's a title bar for 'kali@kali: ~'. Below it, a command prompt shows the execution of a SQL query: `grep -A 20 -i 'INSERT INTO `staff`' ~/mediroza-pentest/recon/mediroza_db_backup_2019.sql`. The output of the query is displayed in a light-colored font, showing a list of employee records with columns for id, full_name, job_title, department, email, phone, national_id, and monthly_salary. The records are listed in a table-like format, with each row representing an employee's details.

7.4 Shareholder Data Exposure

The exposed database also contained a shareholders table containing confidential ownership information.

The following fields were identified:

- Shareholder name
- Ownership percentage
- Shares held
- Share class

The assessment identified ownership information for 10 shareholders. The listed ownership percentages represented the complete ownership information contained within the exposed table.

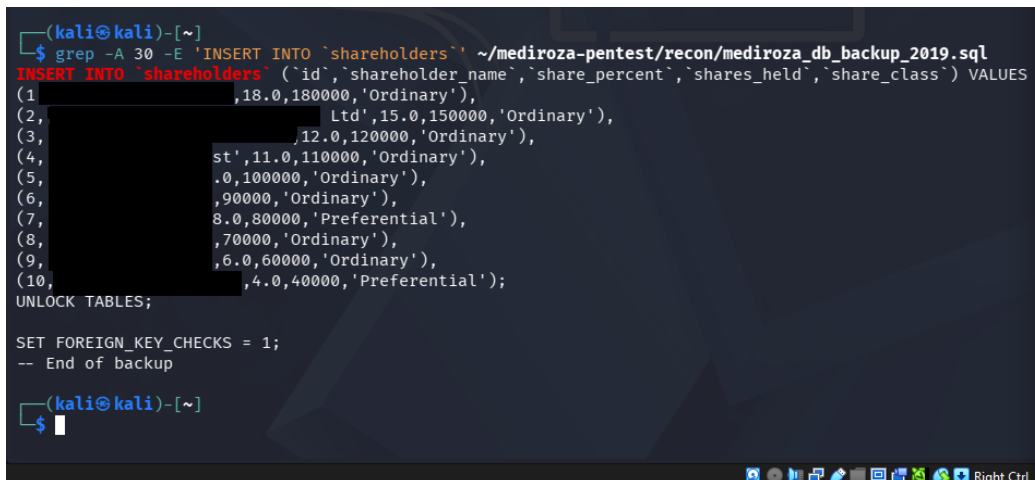
Impact

Unauthorized disclosure of shareholder information may expose confidential ownership and organizational information.

This information could be used to identify ownership structures, individual stakeholders, and the distribution of organizational shares.

Evidence

Figure 7.3 – SQL output demonstrating exposed shareholder information.



```
(kali㉿kali)-[~]
$ grep -A 30 -E 'INSERT INTO `shareholders`' ~/mediroza-pentest/recon/mediroza_db_backup_2019.sql
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1, ,18.0,180000,'Ordinary'),
(2, ,Ltd',15.0,150000,'Ordinary'),
(3, ,12.0,120000,'Ordinary'),
(4, ,st',11.0,110000,'Ordinary'),
(5, ,.0,100000,'Ordinary'),
(6, ,90000,'Ordinary'),
(7, ,8.0,80000,'Preferential'),
(8, ,70000,'Ordinary'),
(9, ,6.0,60000,'Ordinary'),
(10, ,4.0,40000,'Preferential');
UNLOCK TABLES;

SET FOREIGN_KEY_CHECKS = 1;
-- End of backup

(kali㉿kali)-[~]
$
```

8.RISK RATING SUMMARY

The confirmed findings were assessed according to their potential impact on the confidentiality, integrity, and availability of the Mediroza environment.

Finding	Severity	Primary Impact
Milestone-1	High	Unauthorized application access
Milestone-2	High	Unauthorized access to protected patient documents
Milestone-3	Critical	Exposure of sensitive employee and shareholder information

8.1 Overall Risk

The assessment identified a chain of weaknesses that could allow an attacker to progress from initial unauthorized access to sensitive information exposure.

The highest-risk finding was M3 – Critical Data Exposure, where sensitive employee salary and shareholder ownership information was accessible through the exposed database resources.

8.2 Risk Priority

CRITICAL

M3 – Critical Data Exposure

HIGH

M1 – Initial Access

M2 – Data Extraction

9.RECOMMENDATIONS & REMEDIATION

The following actions are recommended to address the confirmed vulnerabilities and reduce the risk of unauthorized access and sensitive data exposure.

9.1 Priority 1 — Immediate

- Remediate the confirmed SQL Injection vulnerability using parameterized queries or prepared statements.
- Remove the exposed old database backup from the publicly accessible web directory.
- Disable unnecessary directory indexing and prevent direct access to backup files.
- Investigate whether the exposed database backup or sensitive information was accessed by unauthorized parties.
- Restrict unauthorized access to employee salary and shareholder information.

9.2 Priority 2 — High

- Strengthen authentication using secure password hashing and appropriate account-security controls.
- Implement MFA for sensitive accounts and administrative functionality where applicable.
- Implement rate limiting, account lockout, and effective CSRF protection.
- Replace weak or static PDF passwords with strong, securely managed secrets.
- Enforce application-level authorization before allowing access to protected documents.

9.3 Priority 3 — Medium

- Use generic authentication error messages to reduce account enumeration.
- Minimize unnecessary technology and version disclosure through HTTP headers and application responses.
- Implement monitoring for failed logins, SQL Injection patterns, suspicious requests, and unauthorized file access.
- Store backups outside the publicly accessible web root and restrict access to authorized personnel.
- Encrypt sensitive backups and periodically review backup security.

10.CONCLUSION

The penetration testing assessment of the Mediroza General Hospital web application demonstrated that multiple security weaknesses could be combined to achieve unauthorized access and exposure of sensitive information.

The assessment progressed through the following stages:

M1 – Initial Access Authentication weaknesses allowed unauthorized access to the application and patient portal, including access to three patient reports.

M2 – Data Extraction The retrieved patient reports were assessed for document protection weaknesses. PDF hashes were extracted, and passwords were recovered, allowing the documents to be decrypted and verified.

M3 – Critical Data Exposure An exposed database backup and SQL Injection provided access to sensitive database information, including employee salary records and shareholder ownership information.

The identified weaknesses demonstrate a significant confidentiality risk. In particular, the combination of unauthorized application access, exposed database resources, weak document protection, and access to sensitive organizational information increases the potential impact of an attack.

The recommended remediation actions should be prioritized according to the risk levels identified in this report. Following remediation, the affected functionality should be retested to verify that the vulnerabilities have been effectively addressed.

Author

Yuvraj Atul Kale (Cybersecurity Student)

Program Name: Cybersecurity program at Networkwalks

LinkedIn: <https://www.linkedin.com/in/yuvraj-kale-936034380?>

GitHub Repository: <https://github.com/yuvraj kale263-max/networkwalks-B082-Week4-Penetration-Testing-Report>